Laboratorio SAMBA

Se realiza el reconocimiento realizando el escaneo con Nmap.
Comando: nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap

```
Host is up, received arp-response (0.000014s latency).
Scanned at 2026-04-10 09:35:42 -05 for 14s
Not shown: 65532 closed tcp ports (reset)
PORT    STATE SERVICE     REASON         VERSION
22/tcp  open  ssh         syn-ack ttl 64 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 bc:86:97:aa:ee:60:bd:01:f2:ca:b9:d5:5d:e3:ae:f9 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQCsBUzPEpRA//D39Sm7fLpgB+4hNVRypxqQYRgoTHCPTc0qH0UqZPihYAKV/K+FHvdbKb83rA0ZtV+678fvwVRnfqjBWDS8O8iQMS7kherh7s1cyO7j
pGMRhhjysAbpqJqDlUiLGmwcXSeRNn6mYYMtaw/17YvIQMFFfUq+WwMWy7ic061R3QeTkJAr1EFVCB/xR/9PiwLx25Bcabqe6stk+ypIyZBTx1lTcMieraXlazkPDG2QC/u0hTfQwdF903DMoV4ESw9qdh
zzJCXp2fwGxJTdjOWJPnjC9XTWcZq8287/vbif8UCTTbBMXyvgnTGYkHSz+a1nDDIgrvBt6GIB+YXVqvkdX5veyR9XuUrJojHWdIYhoDxmgYU8bv8q8kCyflZsSedKzbZFgm4algXaR1ExjP/JXsE+fzNs
cUf0XXsp95J7lzLqACYEWo6rLd+XPuzNQtDhsf048Vxq1cCEdjJM=
|   256 8f:c0:63:c9:cb:6f:f3:ec:66:04:c5:0a:ff:93:2c:07 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBEN5yQ8KqTBoTz+OcEVztz6i735erEp0Bz75v1hZsUIlHT104y4Rff+9dv4amGJOQF7DNbjdlYx2bC7M
|   256 1b:5e:93:85:03:34:0c:fd:42:76:e3:0a:c4:8b:95:2b (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIN3pZENK5hbBeHHpZJUSOHLSxp+g0+/RRHlQshYCW/24
139/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 4
445/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 4
MAC Address: F6:8F:F3:D9:32:86 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-time:
|   date: 2026-04-10T14:35:56
|_  start_date: N/A
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 39571/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 58197/udp): CLEAN (Failed to receive data)
|   Check 4 (port 64350/udp): CLEAN (Failed to receive data)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| nbstat: NetBIOS name: SAMBA, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| Names:
|   SAMBA<00>            Flags: <unique><active>
|   SAMBA<03>            Flags: <unique><active>
|   SAMBA<20>            Flags: <unique><active>
```

```
|_    Message signing enabled but not required
| nbstat: NetBIOS name: SAMBA, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| Names:
|   SAMBA<00>            Flags: <unique><active>
|   SAMBA<03>            Flags: <unique><active>
|   SAMBA<20>            Flags: <unique><active>
|   \x01\x02__MSBROWSE__\x02<01>  Flags: <group><active>
|   WORKGROUP<00>        Flags: <group><active>
|   WORKGROUP<1d>        Flags: <unique><active>
|   WORKGROUP<1e>        Flags: <group><active>
| Statistics:
|   00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|   00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|_  00 00 00 00 00 00 00 00 00 00 00 00 00 00
|_clock-skew: 0s
```

Finalizado el escaneo se detecta las siguiente novedades:

- Puerto 22 servicio SSH.
- Puertos 139/445 servicio SMB, el script smb2

-security-mode indica que el “Message signing enabled nor required”. Esto hace que el host sea vulnerable a ataques SMB Relay si hubiera otros equipos en la red.

Procedemos ejecutando la herramienta enum4linux para enumerar de esta manera usuarios, carpetas compartidas y los permisos que llegan a tener.

EL comando es: enum4linux -a 172.17.0.2

En la búsqueda encontramos los usuarios y directorios compartidos.

```
┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# enum4linux -a 172.17.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Apr 10 09:47:40 2026

 ========================================( Target Information )========================================

Target ........... 172.17.0.2
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none


 ============================( Enumerating Workgroup/Domain on 172.17.0.2 )============================


[+] Got domain/workgroup name: WORKGROUP


 ================================( Nbtstat Information for 172.17.0.2 )================================

Looking up status of 172.17.0.2
        SAMBA           <00> -         B <ACTIVE>  Workstation Service
        SAMBA           <03> -         B <ACTIVE>  Messenger Service
        SAMBA           <20> -         B <ACTIVE>  File Server Service
        ..__MSBROWSE__. <01> - <GROUP> B <ACTIVE>  Master Browser
        WORKGROUP       <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
        WORKGROUP       <1d> -         B <ACTIVE>  Master Browser
        WORKGROUP       <1e> - <GROUP> B <ACTIVE>  Browser Service Elections

        MAC Address = 00-00-00-00-00-00

 ========================================( Session Check on 172.17.0.2 )========================================
```

```
[+] Server 172.17.0.2 allows sessions using username '', password ''

 ================================( Getting domain SID for 172.17.0.2 )================================

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup


 ========================================( OS information on 172.17.0.2 )========================================


[E] Can't get OS info with smbclient


[+] Got OS info for 172.17.0.2 from srvinfo:
        SAMBA          Wk Sv PrQ Unx NT SNT SAMBA Corporate Server
        platform_id     :       500
        os version      :       6.1
        server type     :       0x809a03


 ========================================( Users on 172.17.0.2 )========================================

index: 0x1 RID: 0x3e8 acb: 0x00000010 Account: alice    Name:   Desc:
index: 0x2 RID: 0x3ea acb: 0x00000010 Account: carol    Name:   Desc:
index: 0x3 RID: 0x3e9 acb: 0x00000010 Account: bob      Name:   Desc:
index: 0x4 RID: 0x3eb acb: 0x00000010 Account: admin    Name:   Desc:

user:[alice] rid:[0x3e8]
user:[carol] rid:[0x3ea]
user:[bob] rid:[0x3e9]
user:[admin] rid:[0x3eb]
```

```
=========================================( Users on 172.17.0.2 )=========================================

index: 0×1 RID: 0×3e8 acb: 0×00000010 Account: alice    Name:   Desc:
index: 0×2 RID: 0×3ea acb: 0×00000010 Account: carol    Name:   Desc:
index: 0×3 RID: 0×3e9 acb: 0×00000010 Account: bob      Name:   Desc:
index: 0×4 RID: 0×3eb acb: 0×00000010 Account: admin    Name:   Desc:

user:[alice] rid:[0×3e8]
user:[carol] rid:[0×3ea]
user:[bob] rid:[0×3e9]
user:[admin] rid:[0×3eb]

=================================( Share Enumeration on 172.17.0.2 )=================================

smbXcli_negprot_smb1_done: No compatible protocol selected by server.

        Sharename       Type      Comment
        ---------       ----      -------
        Public          Disk
        Documents       Disk
        Backups         Disk
        IT              Disk
        Admin           Disk
        IPC$            IPC       IPC Service (SAMBA Corporate Server)
Reconnecting with SMB1 for workgroup listing.
Protocol negotiation to server 172.17.0.2 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 172.17.0.2

//172.17.0.2/Public     Mapping: OK Listing: OK Writing: N/A
//172.17.0.2/Documents  Mapping: OK Listing: OK Writing: N/A
//172.17.0.2/Backups    Mapping: DENIED Listing: N/A Writing: N/A
//172.17.0.2/IT Mapping: DENIED Listing: N/A Writing: N/A
//172.17.0.2/Admin      Mapping: DENIED Listing: N/A Writing: N/A
```

```
[+] Enumerating users using SID S-1-5-21-1432696905-332691206-2681074855 and logon username '', password ''

S-1-5-21-1432696905-332691206-2681074855-501 SAMBA\nobody (Local User)
S-1-5-21-1432696905-332691206-2681074855-513 SAMBA\None (Domain Group)
S-1-5-21-1432696905-332691206-2681074855-1000 SAMBA\alice (Local User)
S-1-5-21-1432696905-332691206-2681074855-1001 SAMBA\bob (Local User)
S-1-5-21-1432696905-332691206-2681074855-1002 SAMBA\carol (Local User)
S-1-5-21-1432696905-332691206-2681074855-1003 SAMBA\admin (Local User)

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''

S-1-22-1-1000 Unix User\alice (Local User)
S-1-22-1-1001 Unix User\bob (Local User)
S-1-22-1-1002 Unix User\carol (Local User)
S-1-22-1-1003 Unix User\admin (Local User)

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''

S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)
```

Se procede a listar los recursos compartidos usando smbclient.

smbclient //172.17.0.2/Documents -N

```
┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# smbclient //172.17.0.2/Documents -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Feb 14 02:28:20 2026
  ..                                  D        0  Sat Feb 14 02:28:18 2026
  contracts                           D        0  Sat Feb 14 02:28:20 2026
  credentials.txt                     N      578  Sat Feb 14 02:28:20 2026
  README.txt                          N      336  Sat Feb 14 02:28:19 2026

                113735876 blocks of size 1024. 68128944 blocks available
smb: \> ls -al
NT_STATUS_NO_SUCH_FILE listing \-al
smb: \> get credentials.txt
getting file \credentials.txt of size 578 as credentials.txt (141,1 KiloBytes/sec) (average 141,1 KiloBytes/sec)
smb: \> get README.txt
getting file \README.txt of size 336 as README.txt (82,0 KiloBytes/sec) (average 111,6 KiloBytes/sec)
smb: \> ls
  .                                   D        0  Sat Feb 14 02:28:20 2026
  ..                                  D        0  Sat Feb 14 02:28:18 2026
  contracts                           D        0  Sat Feb 14 02:28:20 2026
  credentials.txt                     N      578  Sat Feb 14 02:28:20 2026
  README.txt                          N      336  Sat Feb 14 02:28:19 2026

                113735876 blocks of size 1024. 68128756 blocks available
smb: \> cd /contracts
smb: \contracts\> ls
  .                                   D        0  Sat Feb 14 02:28:20 2026
  ..                                  D        0  Sat Feb 14 02:28:20 2026
  invoice_2026.txt                    N       68  Sat Feb 14 02:28:20 2026

                113735876 blocks of size 1024. 68128756 blocks available
smb: \contracts\> get invoice_2026.txt
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \contracts\invoice_2026.ttxt
smb: \contracts\> get invoice_2026.txt
getting file \contracts\invoice_2026.txt of size 68 as invoice_2026.txt (16,6 KiloBytes/sec) (average 79,9 KiloBytes/sec)
smb: \contracts\> exit
```

Procedemos con la escalada de privilegios explorando en las carpetas compartidas, encontrando diversos archivos de información que se irá descargando con el comando GET, estos se descargaran en la ruta de que esté abierta en el momento.
Al explorar el archivo mas relevante es cresentials.txt, donde se encuentra lo siguiente:

```
┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# ls
credentials.txt  invoice_2026.txt  README.txt  samba.tar  Scan_Nmap.gnmap  Scan_Nmap.nmap  Scan_Nmap.xml  startlab.sh

┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# cat credentials.txt
═══ CREDENCIALES DEL SISTEMA ═══
Última actualización: Febrero 2026

IMPORTANTE: Contraseñas en Base64

Usuario: alice
Password: WDl0QjdtUTJyTAo=
Acceso: Backups (READ + WRITE)

Usuario: bob
Password: cDRaazhOdzFWago=
Acceso: IT (READ)

Usuario: carol
Password: UjdoVDNjWTlzRgo=
Acceso: Public, Documents (READ)

Usuario: admin
Password: bTJKcTZMeDhEego=
Acceso: Todos los shares + SSH

NOTA DE SEGURIDAD:
- Las contraseñas deben cambiarse cada 90 días
- No compartir credenciales entre departamentos
- Reportar cualquier acceso no autorizado
```

Procedemos con la escalada de privilegios explorando en las carpetas compartidas, encontrando diversos archivos de información que se irá descargando con el comando GET, estos se descargaran en la ruta de que esté abierta en el momento.

Los usuarios están con clave base64 y con esto podemos hacer conexión por SSH con el usuario admin, de todas formas se procede a decodificar con todos las claves de cada uno de los usuarios.

```
┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# echo WDl0QjdtUTJyTAo= | base64 -d
X9tB7mQ2rL

┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# echo cDRaazhOdzFWago= | base64 -d
p4Zk8Nw1Vj

┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# echo UjdoVDNjWTlzRgo= | base64 -d
R7hT3cY9sF

┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# echo bTJKcTZMeDhEego= | base64 -d
m2Jq6Lx8Dz

┌──(root㉿Pentest)-[/home/…/Escritorio/Laboratorios SUID/samba/samba]
└─# ssh alice@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@    WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!     @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:OeZk2qDYF3dEWE49nbBWy+lXuv4tD6aSzoyZkZVza10.
Please contact your system administrator.
Add correct host key in /root/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /root/.ssh/known_hosts:2
  remove with:
  ssh-keygen -f '/root/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

Alice tiene acceso a Backups según el documento de crediales, buscamos coincidencias con dicha palabra. Encontrando un comentario que “Los backups reales se almacenan en /mnt/backups”

Comando: find / -type d -name "*backup*" 2>/dev/null

```
alice@samba:~$ find / -type d -name "*backup*" 2>/dev/null
/var/backups
/mnt/backups
/srv/samba/backups
alice@samba:~$ ls -l /srv/samba/backups
total 4
-rw-r--r-- 1 root root 122 Feb 14 02:28 old_backup.tar.gz.txt
alice@samba:~$ ls -l /mnt/backups
total 0
alice@samba:~$ file /srv/samba/backups/old_backup.tar.gz.txt
/srv/samba/backups/old_backup.tar.gz.txt: UTF-8 Unicode text
alice@samba:~$ cat /srv/samba/backups/old_backup.tar.gz.txt
# Simulación de backup antiguo
# Este archivo es solo de demostración
# Los backups reales se almacenan en /mnt/backups
alice@samba:~$ ls -al /mnt/backups
total 8
drwxrwxrwx 1 alice alice 4096 Feb 14 02:28 .
drwxr-xr-x 1 root  root  4096 Feb 14 02:28 ..
alice@samba:~$ pwd
/home/alice
alice@samba:~$ ls
alice@samba:~$ ls -la
total 28
drwx------ 1 alice alice 4096 Apr 10 10:05 .
drwxr-xr-x 1 root  root  4096 Feb 14 02:28 ..
-rw-r--r-- 1 alice alice  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 alice alice 3771 Feb 25  2020 .bashrc
drwx------ 2 alice alice 4096 Apr 10 10:05 .cache
-rw-r--r-- 1 alice alice  807 Feb 25  2020 .profile
alice@samba:~$ ls -la /mnt/backups
total 8
drwxrwxrwx 1 alice alice 4096 Feb 14 02:28 .
drwxr-xr-x 1 root  root  4096 Feb 14 02:28 ..
alice@samba:~$ cd /var/backups
alice@samba:/var/backups$ ls
alice@samba:/var/backups$ ls -la
total 12
```

Usando el usuario admin se procede a escalar privilegios.

Comando: ssh admin@172.17.0.2

Ahora solo toca escalar privilegio y buscar la flag.
Comando: sudo su

```
alice@samba:/var/backups$ nano /mnt/backups/passwd.bak
alice@samba:/var/backups$ ssh admin@172.17.02
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ECDSA key fingerprint is SHA256:dlS/VoVFFeYO1GrpfByPNSpE4n3iy/rb2imxzEuciTg.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ECDSA) to the list of known hosts.
admin@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@samba:~$ sudo su
root@samba:/home/admin# m2Jq6Lx8Dz
bash: m2Jq6Lx8Dz: command not found
root@samba:/home/admin# ls
root@samba:/home/admin# whoami
root
root@samba:/home/admin# ls -al
total 28
```

Ahora solo toca escalar privilegio y bu
Comando: sudo su

```
admin@samba:~$ sudo su
root@samba:/home/admin# m2Jq6Lx8Dz
bash: m2Jq6Lx8Dz: command not found
root@samba:/home/admin# ls
root@samba:/home/admin# whoami
root
root@samba:/home/admin# ls -al
total 28
drwx------ 1 admin admin 4096 Apr 10 10:19 .
drwxr-xr-x 1 root  root  4096 Feb 14 02:28 ..
-rw-r--r-- 1 admin admin  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 admin admin 3771 Feb 25  2020 .bashrc
drwx------ 2 admin admin 4096 Apr 10 10:18 .cache
-rw-r--r-- 1 admin admin  807 Feb 25  2020 .profile
-rw-r--r-- 1 admin admin    0 Apr 10 10:19 .sudo_as_admin_successful
root@samba:/home/admin# sudo su
root@samba:/home/admin# cat /root/flag.txt
SAMBA{smb_3num_upl04d_cr0n_pr1v3sc_2026}
root@samba:/home/admin#
root@samba:/home/admin#
```

Encontramos la flag.

```
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde samba.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

 LAB: SAMBA
 DIFICULTAD: ★★★☆☆☆☆ básico-medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato SAMBA{ ... }): SAMBA{smb_3num_upl04d_cr0n_pr1v3sc_2026}

¡Felicitaciones! Has conquistado SAMBA.

FECHA Y HORA: 2026-04-10 10:20:19 -0500

[*] Presiona Ctrl+C para eliminar el laboratorio
```